

Audit qualite et securite de la stack open source

Projet SecureBox - TP1 - Acme Corp

1. Objectif et perimetre

Ce rapport presente l'audit initial de la stack open source retenue pour SecureBox. Les trois composants etudies sont Nextcloud, Keycloak et Suricata. L'objectif est d'evaluer la maturite des projets, la securite de leur gouvernance et l'exposition aux vulnerabilites connues avant tout deploiement.

Les analyses realisees incluent OpenSSF Scorecard pour les trois projets, la generation d'un SBOM CycloneDX et un scan CVE Trivy sur Nextcloud. Les resultats CVE presentes ci-dessous proviennent du scan local Trivy realise sur le depot Nextcloud clone dans audit/sources/nextcloud.

2. Methodologie

Controle	Outil	Perimetre	Sortie attendue
Qualite / gouvernance	OpenSSF Scorecard	Nextcloud, Keycloak, Suricata	audit/scorecard-*.json
Inventaire logiciel	Trivy SBOM	Nextcloud	audit/sbom-nextcloud.cdx.json
Veille CVE dependances	Trivy vuln scan	Nextcloud	audit/trivy/nextcloud-vulns-all.json et .csv
Synthese risque	Analyse manuelle	Stack globale	rapport-audit.pdf

3. Resultats OpenSSF Scorecard

Les fichiers Scorecard ont ete generes dans le dossier audit/. Les scores exacts sont a reprendre depuis les fichiers JSON locaux avec la commande `jq '.score' audit/scorecard-*.json`. Cette etape permet de couvrir la gouvernance des projets : maintenance, politique de securite, revue de code, CI/tests, branch protection, dependances et pratiques de release.

Projet	Fichier	Points a analyser dans le rapport
Nextcloud	audit/scorecard-nextcloud.json	Maintained, Security-Policy, Branch-Protection, Code-Review, CI-Tests, Vulnerabilities
Keycloak	audit/scorecard-keycloak.json	Projet critique IAM : revue de code, releases signees, politique de securite, tests CI
Suricata	audit/scorecard-suricata.json	Projet securite reseau : maintenance, fuzzing, SAST, packaging et gouvernance communautaire

4. SBOM CycloneDX - Nextcloud

Un SBOM CycloneDX a ete genere pour Nextcloud : `audit/sbom-nextcloud.cdx.json`. Il constitue un inventaire des composants logiciels et dependances detectes : packages npm/composer, versions, licences, dependances directes et indirectes. Le SBOM ne remplace pas un scan CVE : il sert de base a la tracabilite et a la veille continue.

5. Resultats CVE - Nextcloud

Le scan Trivy a identifie 6 vulnerabilites sur les dependances Nextcloud analysees. Aucune vulnerabilite CRITICAL n'a ete remontee dans les resultats fournis. Les risques les plus notables sont des vulnerabilites MEDIUM avec un score CVSS jusqu'a 7.5.

CVE	Package	Version	Correctif	Sev.	CVSS	Risque
CVE-2026-41907	uuid	12.0.0	11.1.1 / 12.0.1 / 13.0.1	MEDIUM	7.5	Out-of-bounds write : impact potentiel sur integrite et confidentialite.
CVE-2026-33750	brace-expansion	2.0.2	5.0.5 / 3.0.2 / 2.0.3 / 1.1.13	MEDIUM	7.5	Denial of Service via motif brace avec valeur de pas a zero.
CVE-2026-41305	postcss	8.5.8	8.5.10	MEDIUM	6.1	XSS via echappement incorrect des balises de fermeture de style.
CVE-2026-41305	postcss	8.5.6	8.5.10	MEDIUM	6.1	Meme CVE detectee sur une autre version de PostCSS.
CVE-2025-14505	elliptic	6.6.1	Non precise	LOW	5.6	Defaults de gestion de clefs dans elliptic.
CVE-2024-9506	vue	2.7.16	3.0.0-alpha.0	LOW	3.7	Regular Expression Denial of Service (ReDoS).

6. Classement des risques

Niveau	Constat	Impact	Priorite
Critical	Aucune CVE critique detectee par le scan Trivy fourni.	Pas de blocage immediat identifie sur Nextcloud via ce scan.	Surveillance continue
High	Aucune CVE HIGH detectee dans les resultats fournis.	Le risque reste a surveiller via NVD/OSV et mises a jour regulieres.	Surveillance continue
Medium	4 occurrences MEDIUM : uuid, brace-expansion, postcss.	Risque d indisponibilite, XSS ou atteinte a l integrite selon contexte d exposition.	Correction prioritaire
Low	2 occurrences LOW : elliptic et vue.	Impact plus limite, mais a traiter dans le cycle de maintenance.	Correction planifiee

7. Recommandations

1. Mettre a jour les dependances vulnérables : uuid vers 12.0.1 ou version supérieure, postcss vers 8.5.10, brace-expansion vers une version corrigée adaptée à la branche utilisée.
2. Intégrer Trivy dans la chaîne CI/CD afin de bloquer ou signaler les dépendances CRITICAL/HIGH avant déploiement. Conserver les rapports JSON/TXT dans le dossier audit/ lors des TP.
3. Conserver et versionner un SBOM CycloneDX à chaque version audité. Le SBOM permet de savoir rapidement si une dépendance impactée est présente lorsqu'une nouvelle CVE est publiée.
4. Compléter l'analyse par une veille NVD/OSV.dev, notamment pour les vulnérabilités applicatives Nextcloud qui peuvent ne pas être détectées uniquement par l'analyse de dépendances.
5. Pour la mise en production, privilégier une version stable maintenue, limiter l'exposition publique, activer MFA/SSO lorsque possible, durcir la configuration TLS et appliquer une politique de sauvegarde et de restauration testée.

8. Conclusion

L'audit ne met pas en évidence de vulnérabilité critique dans les dépendances Nextcloud scannées, mais plusieurs dépendances présentent des vulnérabilités MEDIUM qui doivent être corrigées avant un déploiement de production. La stack doit être accompagnée d'une hygiène de maintenance : mises à jour régulières, suivi CVE, conservation des SBOM et contrôles automatisés dans le dépôt Git SecureBox.

Les fichiers attendus pour la preuve technique sont présents dans audit/ : scorecards JSON, SBOM CycloneDX Nextcloud et rapports Trivy CVE. Le rapport devra être mis à jour avec les scores numériques Scorecard exacts extraits depuis les fichiers JSON locaux avant rendu final si ces scores ne sont pas déjà ajoutés au tableau d'audit.

Annexes - commandes utilisées

```
scorecard --repo=github.com/nextcloud/server --show-details --format=json -o audit/scorecard-nextcloud.json
scorecard --repo=github.com/keycloak/keycloak --show-details --format=json -o audit/scorecard-keycloak.json
scorecard --repo=github.com/OISF/suricata --show-details --format=json -o audit/scorecard-suricata.json
trivy fs --format cyclonedx --output audit/sbom-nextcloud.cdx.json audit/sources/nextcloud
trivy fs --scanners vuln --format json --output audit/trivy/nextcloud-vulns-all.json audit/sources/nextcloud
```